

Security Assessment Report

Target: Slush (Sui Wallet) ecosystem — web properties (slush.app), Chrome extension v26.18.0, Android app v2 (26.18.0 / code 122), and related services.

Type: Authorized external security review (non-destructive) | Date: 24 August 2026

1. Executive Summary

Two **CONFIRMED CRITICAL** issues were reproduced live against production infrastructure:

- A **production Enoki API key** is hardcoded in the shipped Chrome extension and Android app (unrotated across versions), and is live — a benign API call with the key returned HTTP 200 and disclosed the wallet’s full OAuth configuration.
- The wallet’s Enoki OAuth application is configured with `allowedOrigins: []`, so **any website origin** may use the wallet’s OAuth / zkLogin identity flow (an identity-phishing enabler).

One **HIGH** is statically confirmed (Android backup data-extraction gap). One **HIGH** remains theoretical (mobile dApp WebView bridge lacks an origin allow-list) — dynamic confirmation was blocked because the supplied APK is an incomplete App-Bundle base split with no native libraries. The live API backend is otherwise well-hardened (persisted-query-only GraphQL, Vercel-protected staging, client-only Statsig key).

2. Findings Overview

ID	Finding	Severity	Status	PoC
C-01	Production Enoki API key embedded in shipped clients (extension + Android), unrotated	CRITICAL	CONFIRMED	Reproduced (live HTTP 200)
C-02	Enoki OAuth <code>allowedOrigins: []</code> — any origin may use the wallet’s identity app	CRITICAL	CONFIRMED	Reproduced (live config)
H-01	Android backup/data-extraction rules leave MMKV/AsyncStorage/Realm exposed	HIGH	CONFIRMED (static)	Config evidence
H-02	Mobile dApp WebView bridge: no origin allow-list (approval origin-binding unverified)	HIGH*	THEORETICAL	Blocked (incomplete APK)
M-01	Stripe on-ramp: 5 exported deep-link activities; <code>stripe-connect://</code> no host restriction	MEDIUM	Confirmed	Manifest

M-02	AppsFlyer + expanded deep-link schemes/hosts (OneLink, sui://, zksend, etc.)	MEDIUM	Confirmed	Manifest
M-03	Over-broad Android permissions (location, microphone, overlay, storage)	MEDIUM	Confirmed	Manifest
M-04	Sentry DSNs embedded (2 projects) — error-quota abuse / PII in breadcrumbs	MEDIUM	Confirmed	Bundle strings
M-05	Extension: 24-hour approval expiry per tab+method (auto-approve window)	MEDIUM	Confirmed	Code
M-06	Relay/sync data layer (api.slush.app) — tenant isolation to verify	MEDIUM	Confirmed	Code
M-07	my.slush.app serves Framer marketing page; Android assetlinks dead	MEDIUM	Confirmed	Live probe
M-08	Stripe on-ramp completion: server-side payment verification must be validated (internal)	MEDIUM	Confirmed	Flow analysis

* H-02 carries no severity until dynamically verified.

3. Critical Findings (Reproduced)

C-01 — Production Enoki API key embedded in shipped clients

Affected: extension `background.js`; Android APK v2 bundle. The Enoki client is instantiated with a hardcoded production key, unrotated from the previous build.

```
// Static extraction (shipped extension)
$ grep -oE 'new VD\\(\\{apiKey:"enoki_apikey_[a-f0-9]+' background.js
new VD({apiKey:"enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a

// Live validation
$ curl -H "x-enoki-api-key: enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
  https://api.enoki.mystenlabs.com/v1/app
HTTP 200 (16.8s)
{"data":{"allowedOrigins":[],"authenticationProviders":[
  {"providerType":"twitch","clientId":"kwioig7uxb90zsgb08fyziwnahmclq"},
  {"providerType":"google","clientId":"768056533295-
s37otp56men05m4ppburuo4sclk6b5a2.apps.googleusercontent.com"},
  ... (Apple x4, Twitch x2, Facebook) ...}]}
```

Impact: credential disclosure; identity-flow abuse; sponsored-transaction / service quota abuse. **Remediation:** rotate the key immediately; remove credentials from client binaries; audit Enoki account activity.

C-02 — Enoki OAuth origin allow-list is empty

The wallet's Enoki application has `allowedOrigins: []` and `domains: []` — the origin allow-list guardrail is effectively disabled. Combined with the disclosed OAuth client IDs (C-01), any website can initiate the wallet's OAuth/zkLogin identity flow.

```
$ curl -s -H "x-enoki-api-key: enoki_apikey_be0da54e9cc92700c2be0118a3eccf6a" \
https://api.enoki.mystenlabs.com/v1/app
{"data":{"allowedOrigins":[],"domains":[],"authenticationProviders":[...]}}
```

Remediation: restrict `allowedOrigins` to the exact trusted host set; rotate the key regardless.

4. High Findings

H-01 — Android backup/data-extraction gap (CONFIRMED, static)

`allowBackup="true"`; backup/extraction rules exclude only the `SecureStore` shared-preferences. The wallet's MMKV (18 refs), `AsyncStorage` (11), and `Realm` stores are separate storage domains and are **not** excluded — they remain included in cloud backup, device-to-device transfer, and `adb backup` (Android < 12).

```
AndroidManifest.xml: android:allowBackup="true"
res/xml/secure_store_data_extraction_rules.xml:
  <cloud-backup><include domain="sharedpref" path="."/>
    <exclude domain="sharedpref" path="SecureStore"/></cloud-backup>
  (same for device-transfer)
Bundle: AsyncStorage x11 | MMKV x18 | Realm x1 | SecureStore x5
```

Remediation: exclude MMKV/Realm/AsyncStorage paths or set `allowBackup="false"`; confirm keys live only in Keystore-backed `SecureStore`.

H-02 — Mobile dApp WebView bridge lacks an origin allow-list (THEORETICAL)

The signing-enabled bridge exposes `signTransaction`, `signAndExecuteTransactionBlock`, `signPersonalMessage`, `requestPermissions`, `getAccounts` to any page in the in-app browser. A full bundle scan found zero origin allow-list / validation primitives (`allowedOrigins`, `trustedOrigins`, `validateOrigin`, `verifyOrigin`, `checkOrigin` — all 0). An approval UI and a user-bypassable scam check exist, but are not backed by an origin allow-list.

PoC attempt — blocked: installing the supplied APK on an Android 11 emulator fails at launch: `couldn't find DSO to load: libreactnative.so` — the artifact is an incomplete App-Bundle base split (0 native libraries). Required: re-export a complete universal APK, then test (a) arbitrary-URL loading via the `browse deep link`, (b) approval-screen origin display, (c) cross-origin reuse of a previously approved origin.

5. Medium Findings (Summary)

- **M-01** Stripe on-ramp deep links: 5 exported BROWSABLE activities; `stripe-connect://` has no host restriction (intent-injection surface).
- **M-02** AppsFlyer + new deep-link schemes/hosts (`slush.onelink.me`, `sui://`, `exp+sui-wallet://`, `suiwallet.com/ul`, `zksend.com/claim`, `my.slush.app/swap`).
- **M-03** Over-broad permissions: precise location, microphone (iOS plist says unused), `SYSTEM_ALERT_WINDOW`, legacy external storage.
- **M-04** Sentry DSNs embedded (2 projects): error-quota abuse; PII-in-breadcrumbs risk.
- **M-05** Extension approvals persist 24h per tab+method — verify no silent auto-approve window.
- **M-06** Relay/sync data layer (`api.slush.app`) — verify tenant isolation; keys must never leave the device.
- **M-07** `my.slush.app` serves a Framer marketing page; `/well-known/assetlinks.json` dead — Android deep-link autoVerify likely broken.
- **M-08** Stripe on-ramp completion: server must verify real payment status (signed webhook) and allow-list redirect URLs. Client contains only the public `pk_live` publishable key (validated: cannot access account data); no `sk_`/`whsec_` anywhere.

6. Low / Informational & Positives

- Cloudflare WAF on all properties; build commit + Sentry release metadata exposed; source maps not exposed.
- `staging.slush.app`: Vercel deployment protection (401) — standard.
`stellate.slush.app`: unreachable/misconfigured (403/421) — remove or fix record.
- `initialize.slush.app/v1`: Statsig gateway; only a public **client** SDK key present (verified live; gates served with hashed names). No secret/conductor keys.
- `api.slush.app`: only `/graphql`; persisted-query-only (introspection + arbitrary queries rejected) — positive hardening.
- Extension is well-hardened: origin-bound authorization, tab-navigation anti-spoofing, URL-scheme guardrail, no XSS/RCE sinks, WebCrypto entropy (CryptoJS absent → CVE-2026-71851 not applicable), no applicable disclosed CVEs in embedded libraries.

7. Endpoint Coverage

Tested: `slush.app`, `www`, `my.slush.app`, `api.slush.app`, `initialize.slush.app/v1` (Statsig), `staging` (Vercel-protected), `stellate` (dead), `support` (Zendesk), `assets.slater.app`, `sui-dev` CDN, `osmo.supply`, `Enoki` (critical confirmed), `Stripe/webhooks` (black-box closed), `Statsig`, `Chrome extension` (deep), `Android APK v1+v2` (static).

Not testable (no artifacts): `iOS app`, `Halliday onramp`, `Moonpay`; `Android WebView-bridge` dynamic test (incomplete APK); `Stripe server-side verification` and `relay tenant isolation` (server-internal).

8. Remediation Priority

1. **Rotate the Enoki API key and restrict `allowedOrigins`** (C-01, C-02) — immediate; live today.
2. **Fix backup/extraction exclusions** (H-01).
3. **Re-export a complete APK and complete the WebView-bridge dynamic test** (H-02).
4. Validate Stripe server-side payment verification, webhook signatures, and relay tenant isolation (M-06, M-08).
5. Remove unjustified permissions; fix `my.slush.app` deployment and `stellate` record (M-03, M-07).

Prepared as an independent authorized security assessment. Severity follows Critical/High/Medium/Low; theoretical findings carry no severity until dynamically verified.